

Supplementary Appendix

Replication Package Document for
Beyond Labels: Evaluating LLMs on Vulnerable-Path Reconstruction

Aly Ahmad and Mahmoud Alfadel

This appendix accompanies the replication package for the paper above. It combines three notes: the identifier-masking contamination check, a case-level analysis of the Claude Sonnet 4.5 fail cases in original Figure 4, and the held-out oracle re-run on Python CVEs disclosed after every evaluated model’s training cutoff.

1 Identifier Masking Contamination Check

This note reports the semantics-preserving identifier-masking experiment used to probe whether RQ₁ path-reconstruction scores reflect training-data memorization rather than reasoning over the provided code.

Because all evaluated CVEs are public, a model might partially recall a vulnerability from training data rather than reason over the provided code. To probe this risk, we re-run the RQ₁ oracle setting on a semantics-preserving masked version of CVEPATH.

Masking. We rename user-defined identifiers to opaque tokens (`Cls_####` / `Fn_####` / `v_####`), rename files to `file_####.ext`, and redact comments, Python docstrings, CVE IDs, and project-name tokens, while keeping language keywords and a blocklist of standard-library and framework source/sink APIs intact. Decoding and aggregation match Table I of the main manuscript.

Results. Table 1 reports paired masked-minus-unmasked differences. If Table I of the main manuscript were driven by memorized public identifiers or filenames, stripping those cues should degrade NOR and LCNr. It does not: for the four strongest models, Holm-corrected NOR p -values are all at least 0.73 and effect sizes are negligible to small. The only significant change is Llama-3.3-70B, which *improves* under masking (NOR +0.16, Holm $p=0.01$, $r=0.39$), the opposite of a memorization signature. The model ordering is preserved. We therefore find no evidence that the Table I numbers reflect identifier memorization on this setting.

Table 1: Paired masked-vs-unmasked RQ₁ comparisons ($n=105$ CVEs). Δ is masked minus unmasked. Win/Tie/Loss = masked higher / equal / lower. p values are Holm-corrected Wilcoxon signed-rank tests within each metric; r is the matched-pairs rank-biserial correlation.

Model	Metric	Δ	p (Holm)	r	Win/Tie/Loss
Claude Sonnet 4.5	NOR	0.03	0.75	0.18	28/53/24
	LCNR	0.00	0.79	0.04	35/39/31
GPT-5.2	NOR	-0.06	0.94	0.01	24/53/28
	LCNR	-0.01	0.64	-0.19	27/49/29
DeepSeek-V3.2	NOR	+0.02	0.73	0.21	29/54/22
	LCNR	0.00	0.21	0.32	31/55/19
GPT-4o	NOR	-0.04	0.84	-0.13	28/53/24
	LCNR	-0.02	0.73	-0.15	25/54/26
Llama-3.3-70B	NOR	+0.16	0.01	0.39	53/27/25
	LCNR	+0.17	0.02	0.40	45/35/25

2 Claude Fail-Case Analysis

This note reports a case-level analysis of the 10 Claude Sonnet 4.5 fail cases in original Figure 4.

2.1 Which cases

Original Figure 4 is a single-run Claude Sonnet 4.5 NOR scatter over 105 CVEs. The 10 NOR = 0 cases points are the right-hand tail of the figure.

The 10 CVEs are CVE-2019-16056, CVE-2021-40323, CVE-2021-43837, CVE-2023-23930, CVE-2022-36081, CVE-2014-3498, CVE-2021-29433, CVE-2023-26051, CVE-2022-45064, and CVE-2021-41131.

2.2 Two dimensions

For every CVE we report both of the following.

Structural and contextual (descriptive). Path length, number of files, input tokens, and input lines, shown against the RQ₃ failure medians (path length 12, 2 files, 12,771 tokens, 852 lines). These summarize the typical low-performing RQ₃ case.

Qualitative reconstruction. A representative predicted path is compared with the retained reference paths and the CVE advisory and given one tag: T3 (CWE Misclassification), T1 (Endpoint Misidentification), or a reference-set gap (the prediction matches the advisory while the annotation encodes parallel flow).

2.3 Results

Five of the ten sit above the RQ₃ failure median for path length or number of files (CVE-2023-26051, CVE-2022-45064, CVE-2019-16056, CVE-2021-41131, CVE-2014-3498), and all five also exceed the input-size benchmarks. Two further cases have short, single-file paths but still exceed both input-size medians. Thus 7 of 10 exhibit relatively high path complexity, large input context, or both. Each of those cases still carries a reconstruction tag: structural complexity and a specific failure mode co-occur rather than substitute.

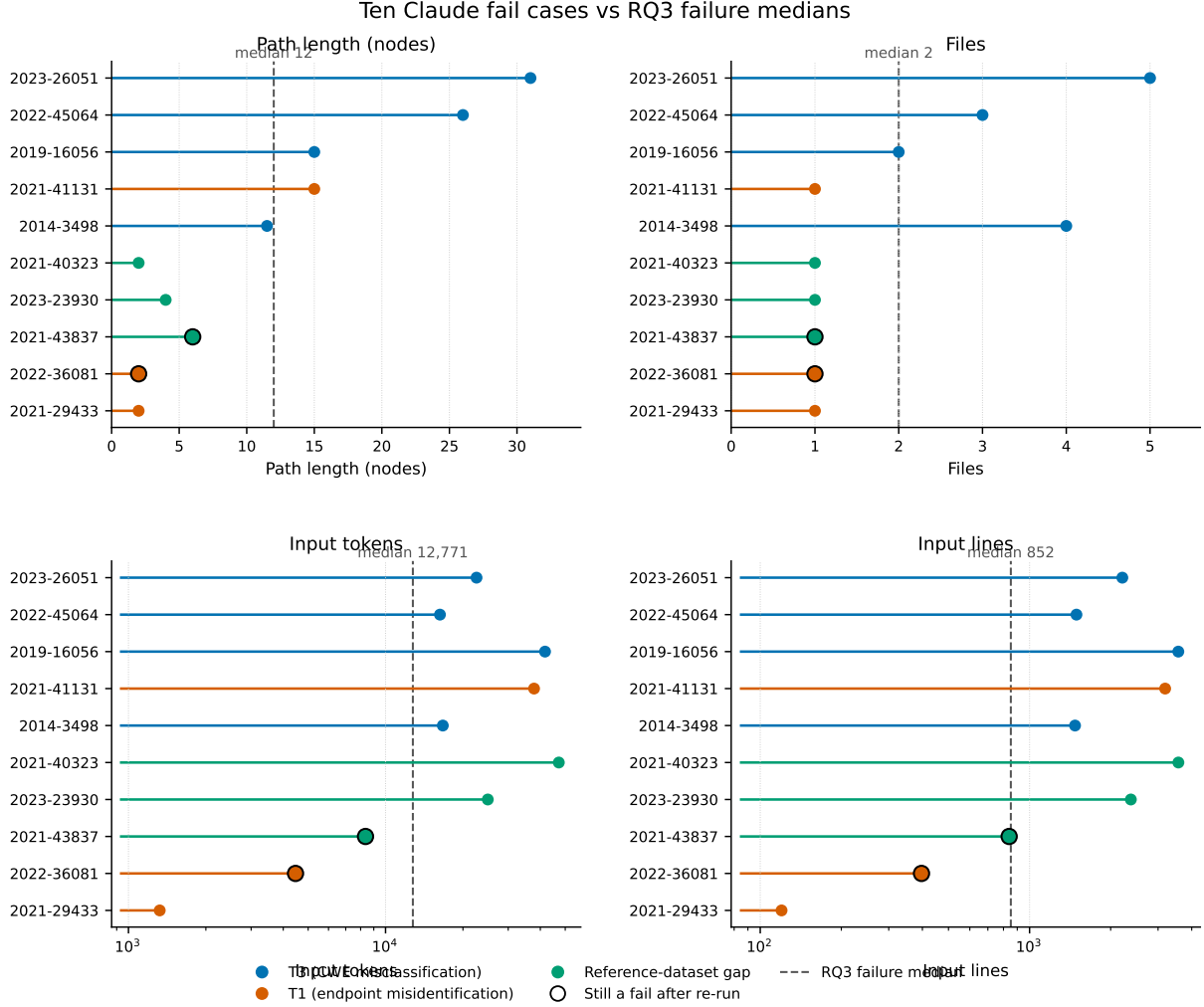


Figure 1: Path length, number of files, input tokens, and input lines for the 10 fail cases in Figure 4, relative to the RQ₃ failure medians (dashed lines). Color denotes the reconstruction tag (T3, T1, or reference-set gap). Tokens and lines are shown on a log axis.

Across all 10, the tags are T3 for four (CVE-2014-3498, CVE-2022-45064, CVE-2023-26051, CVE-2019-16056); T1 for three (CVE-2022-36081, CVE-2021-29433, CVE-2021-41131); and a reference-set gap for three (CVE-2021-40323, CVE-2021-43837, CVE-2023-23930). The three reference-set gaps were excluded from the RQ₂ open-coding of model failure modes.

T1, Endpoint Misidentification. CVE-2022-36081 is a CWE-22 path-traversal vulnerability involving the `/list/<folderpath>` endpoint, where the vulnerable flow can expose server file listings. The retained reference path follows `list_wiki` to `os.walk` and corresponds to this advisory-relevant endpoint. Claude instead reconstructs other flows in the same files related to page-name write/save operations and does not recover the advisory-relevant `/list` source-to-sink path.

T3, CWE Misclassification. CVE-2022-45064 is an include-based cross-site scripting vulnerability in Apache Sling. The retained reference path corresponds to this vulnerability. Claude

instead reports path traversal, dispatcher SSRF, and filter-chain DoS candidates and does not identify the advisory-reported XSS flow.

Reference-set gap. CVE-2023-23930 concerns unsafe pickle-based serialization. Our retained path captures the same serialization flow, but the recorded sink is an exception-throwing line in `serialize()` rather than the pickle operation itself. Claude identifies the pickle serialization of task input described by the advisory. Manual inspection indicates that the prediction represents a valid flow for the same CVE that is not captured by the retained reference path in our dataset, rather than a genuine reconstruction failure.

3 Post-Cutoff Held-Out Reconstruction Check

This note reports the held-out oracle re-run on Python CVEs disclosed after every evaluated model’s training cutoff, used together with identifier masking to probe whether Table I of the main manuscript is driven by memorizing the public CVEPATH cases.

3.1 Cutoff

The newest model in Table I is GPT-5.2, with knowledge cutoff 31 August 2025. We keep a CVE only if both its NVD publish date and its fix-commit date are strictly after that day, so the same 14 CVEs post-date every model in Table I. As in RQ₁, the prompt contains no CVE identifier, CWE, or advisory text.

3.2 Collection and funnel

We construct a Python held-out set with the paper’s CS/PC/PF pipeline, restricted to a post-cutoff window. Discovery starts from reviewed GitHub Advisories for pip packages with a CVE id, requires a public GitHub fix and parent SHA, applies the CS-1 path-problem CWE filter, drops addition-only fixes, and keeps CS-2 vulnerability-path-fixing files. We then build CODEQL databases with `codeql database create --language=python` and no `--command`. Java is omitted because constructing Java databases would require probing per-project build commands.

On the parent checkouts we run augmented path-problem queries, keep paths that overlap the fix hunks (PF-1: 15 CVEs), and apply PF-2: the source and sink must match the CVE, and the intermediate nodes must be a valid taint sequence. Of the 15 PF-1 candidates we drop CVE-2025-12638 as a duplicate keras GHSA of CVE-2025-12060 and retain 14 Python CVEs: CVE-2025-10155, CVE-2025-12060, CVE-2025-61622, CVE-2025-61677, CVE-2025-61765, CVE-2025-67502, CVE-2025-67729, CVE-2026-11529, CVE-2026-11816, CVE-2026-25632, CVE-2026-27645, CVE-2026-27953, CVE-2026-54499, and CVE-2026-8838.

3.3 Experiment

Evaluation matches Table I. We use the LLMPATH prompt with oracle files only ($k=0$), four independent runs per CVE, chat models at temperature 0.2, reasoning models with temperature omitted, and seed 1000 where the provider supports it. CVE-level scores are the median of the four runs; NOR/LCNR are then the median across CVEs and Src-HR/Sink-HR the mean. Each prediction is paired with the retained reference path of maximum NOR.

Table 2: Table I (105 older CVEs) vs. the post-cutoff held-out set (14 CVEs). NOR/LCNR are medians across CVEs; Src-HR/Sink-HR are means. Aggregation matches Table I (median of four runs per CVE).

Model	NOR		LCNR		Src-HR		Sink-HR	
	I	Post	I	Post	I	Post	I	Post
Claude Sonnet 4.5	0.75	0.94	0.50	0.79	0.51	0.64	0.80	0.79
GPT-5.2	0.75	1.00	0.43	0.72	0.51	0.75	0.78	0.89
GPT-4o	0.44	0.58	0.27	0.58	0.41	0.50	0.59	0.71
DeepSeek-V3.2	0.64	0.95	0.36	0.90	0.48	0.71	0.71	0.79
Llama-3.3-70B	0.29	0.50	0.17	0.50	0.27	0.43	0.43	0.61

Table 3: Per-CVE median NOR on the post-cutoff set (median of four runs).

CVE	Claude	GPT-5.2	GPT-4o	DeepSeek	Llama
CVE-2025-10155	0.00	0.00	0.00	0.19	0.12
CVE-2025-12060	0.67	0.75	0.33	0.42	0.50
CVE-2025-61622	0.78	0.89	0.17	0.78	0.28
CVE-2025-61677	1.00	1.00	1.00	1.00	1.00
CVE-2025-61765	1.00	1.00	1.00	1.00	1.00
CVE-2025-67502	1.00	1.00	0.67	1.00	1.00
CVE-2025-67729	1.00	1.00	0.50	1.00	0.25
CVE-2026-11529	1.00	1.00	0.33	1.00	0.00
CVE-2026-11816	0.60	0.80	1.00	0.80	0.40
CVE-2026-25632	0.83	0.75	1.00	1.00	1.00
CVE-2026-27645	1.00	1.00	0.50	0.50	0.50
CVE-2026-27953	0.12	0.80	0.00	0.25	0.10
CVE-2026-54499	0.88	1.00	1.00	0.90	0.50
CVE-2026-8838	1.00	1.00	1.00	1.00	1.00

3.4 Results

Table 2 compares Table I ($n=105$) with the post-cutoff set ($n=14$). No model collapses. Median NOR is 0.94 for Claude Sonnet 4.5, 1.00 for GPT-5.2, 0.95 for DeepSeek-V3.2, 0.58 for GPT-4o, and 0.50 for Llama-3.3-70B, each above that model’s Table I NOR. LCNR and Src-HR also rise; Claude Sink-HR is essentially unchanged (0.80 to 0.79). The set is not trivial: Claude, GPT-5.2, and GPT-4o all have NOR = 0 on CVE-2025-10155 (Table 3).